

29 March 2024

DECISION

Notification of Personal Data Breach Incident

Nicosia Tennis Club (Field Club) – Ref. No. 35/2023

I refer to the Notification of a personal data breach incident submitted to my Office on 26/04/2023, by the Nicosia Tennis Club (Field Club), (hereinafter, the "Club"), as well as to all relevant correspondence regarding the above matter, which forms part of the case file. Based on the duties and powers conferred upon me by Articles 57 and 58 of the General Data Protection Regulation, (EU) 2016/679, (hereinafter, the "Regulation"), I note the following:

2 Case Incidents

2.1. The Notification of the personal data breach incident concerned the loss of the membership registration forms of the Club's tennis academy, which were kept in a locked document storage cabinet in its office.

2.2. These forms contained personal information of the Club's members, such as names and contact details (address and phone number).

2.3. According to the aforementioned Notification, the membership registration forms were stolen from the Club's office by Ms. XXXX.

2.4. My Office contacted Ms. XXXX and requested her positions regarding the Club's claims. In the event that the claims were valid, I called upon Ms. XXXX to return the forms to the Club.

2.5. According to the response letter dated 02/06/2023, to my Office, Ms. XXXX admitted that she was in possession of the membership registration forms of the Club's academy and stated verbatim that they "will remain in the custody of her lawyer."

2.6. Subsequently, my Office contacted Ms. XXXX by phone, who confirmed that the documents were in her possession. The Club requested Ms. XXXX to return the registration forms. Ms. XXXX refused to return them.

2.7. Given that there was an admission from Ms. XXXX that she was in possession of the original registration forms, without any apparent legal basis, on 26/06/2023, I issued an Order to Ms. XXXX to deliver the documents to their lawful holders, namely the Club (Data Controller), pursuant to Article 58(2)(d) of the Regulation. Furthermore, I informed her that possession of the original membership registration forms of the Club's members, without any legal basis, may constitute a criminal offense, pursuant to Article 33 of the Law on the Protection of Natural Persons Against the Processing of Personal Data and the Free Movement of Such Data (125(I)/2018).

2.8. However, the deadline I initially set passed without receiving any response from her. As I was informed by the Club, Ms. XXXX had not returned the documents she possessed.

2.9. As a result of the above and because, based on Article 33(b) of the Law on the Protection of Natural Persons Against the Processing of Personal Data and the Free Movement of Such Data of 2018 (125(I)/2018), non-cooperation with the Commissioner constitutes a criminal offense and because, based on Article 25(e) of the same Law, the Commissioner has the authority "to notify the Attorney General of the Republic and/or the Police of any violation of the provisions of the Regulation or this Law, which may constitute a criminal offense under the provisions of Article 33 of this Law," I referred the examination of the case to the Police, deeming their involvement essential and necessary.

2.10. It is noted that the Club informed its members about the personal data breach incident. However, due to the lack of an electronic registry for the data of the members of the Club's tennis academy, it was not possible to inform all affected members.

2.11. Regarding the measures taken prior to the incident, the Club kept the membership registration

forms in a locked document storage cabinet within the office of the Club's secretary, which has a security lock.

2.12. To address the breach, the Club requested Ms. XXXX, through the responsible person of the Club's academy, to return the membership registration forms to the Club. Due to her failure to return them, the president of the Club...

****Communicate with my Office to be informed about the correct procedure that must be followed.****

2.13. Additionally, to avoid similar incidents in the future, the Group has installed an electronic member registry management program, and all data is managed electronically only by authorized individuals.

2.14. During the examination of the Notification, two complaints were submitted to my Office against the Group:

2.14.1. The first complaint was submitted on 15/06/2023. The complainant had informed the Group via email about an incident that had occurred at one of the Group's venues. As he claimed, the Group forwarded his email to a person to whom the incident pertained. My Office proceeded with the investigation of the case; however, it has not been proven that the complainant's claims regarding the forwarding of the original email by the Group were valid.

2.14.2. Also, through the same complaint, I was informed that when a member of the Group accessed the Group's reservation system, they had the ability to view the names of members and their reservations. Following my Office's intervention, the Group made the necessary adjustments so that only the individuals who created the reservation could see their names and not any third party.

2.14.3. Regarding the second complaint submitted to my Office, it concerned the disclosure of the complainant's personal data in the agenda of the General Assembly, which was posted on the Group's website. I informed the Group that any personal data contained in the minutes should not be disclosed but should be removed or covered before the minutes are posted. The Group acted promptly and corrected the agenda by re-uploading it without disclosing any personal data.

****3. Legal Aspect****

3.1.1. According to Article 4 of the Regulation, personal data is interpreted as "any information relating to an identified or identifiable natural person ('data subject'); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier such as a name, an identification number, location data, an online identifier, or to one or more factors specific to the physical, physiological, genetic, psychological, economic, cultural, or social identity of that natural person."

3.1.2. Under the same Article, "processing" is interpreted as "any operation or set of operations which is performed on personal data or on sets of personal data, whether or not by automated means, such as collection, recording, organization, structuring, storage, adaptation or alteration, retrieval, consultation, use, disclosure by transmission, dissemination or otherwise making available, alignment or combination, restriction, erasure or destruction."

3.1.3. Also, in the same Article, the data controller is defined as "the natural or legal person, public authority, agency or other body which, alone or jointly with others, determines the purposes and means of the processing of personal data; where the purposes and means of such processing are determined by Union law or the law of a Member State, the controller or the specific criteria for its designation may be provided for by Union law or the law of a Member State."

3.2. According to Article 5(1)(f) of the Regulation, personal data shall be processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction or damage, using appropriate technical or organizational measures ("integrity and confidentiality").

3.3. Under Article 24(1) of the Regulation concerning the liability of the data controller, it is provided that, taking into account the nature, scope, context and purposes of the processing, as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons, the data controller

shall implement appropriate technical and organizational measures to ensure and to be able to demonstrate that processing is performed in accordance with this Regulation. Such measures shall be reviewed and updated when necessary.

3.4. Furthermore, according to Article 32 of the Regulation, it is provided that:

"1. Taking into account the state of the art, the costs of implementation and the nature, scope, context and purposes of processing, as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, including, as appropriate: adequate security level against the risks, including, among others, as appropriate:..."

of confidentiality,

the ability to ensure

the pseudonymization and encryption

of personal data

(a) **character,**

(b) **the**

availability and reliability of systems and

processing services on an ongoing basis,

(c) **the ability to restore availability**

and access to personal data in a timely manner in

the event of a physical or technical

incident,

(d) **the effectiveness of technical and organizational**

measures to ensure the

security of processing.

Assessment and evaluation

of integrity,

process for

regular testing,

the

2. **In assessing the appropriate level**

of security, particular account is taken of

the risks arising from processing,

in particular from accidental or unlawful

destruction, loss, alteration, unauthorized

disclosure or access to personal data that has been

transmitted, stored, or otherwise processed.

3.5. **Pursuant to Article 58(2) of the Regulation,**

the Commissioner has the following

corrective powers.

** (a) to issue warnings to the data controller or the**

processor that intended processing operations

are likely to infringe provisions of this Regulation,

** (b)**

to issue reprimands to the data controller or the

processor when processing operations have

infringed provisions of this Regulation,

** (c)**

to order the data controller or the processor

to comply with the data subject's requests to exercise

their rights under this Regulation,

** (d)**

****to order the data controller or the processor****
****to bring processing operations into compliance****
****with the provisions of this Regulation, if necessary, in a specific manner and within a specified timeframe,****
**** (e) ****
****personal data to the data subject,****
**** (f) ****
****prohibition of processing,****
**** (g) ** to order rectification or erasure of personal data or**
****restriction of processing pursuant to Articles****
****16, 17, and 18 and order****
****notification of such actions to recipients****
****to whom the personal data have been disclosed pursuant to****
****Article 17(2) and Article 19,****
**** (h) ****
****to withdraw certification or to order the****
****certification body to withdraw a certificate issued pursuant to Articles 42 and 43 or to order the****
****certification body not to issue****
****certification, if the certification requirements are not met or are no longer met,****
**** (i) ****
****to impose an administrative fine pursuant to****
****Article 83, in addition to or instead of****
****the measures referred to in this paragraph,****
****depending on the circumstances of each****
****individual case,****
**** (j) ****
****to order the suspension of data flows to a recipient in a third****

4. ****Recital****

4.1 ****Considering that the Group decides****
****on the purpose and means of****
****processing personal data received from its members, the Group****
****acts as the data controller of****
****such data, pursuant to Article 4(7)****
****of the Regulation.****

4.2 ****According to Articles 5(1)(f), 24(1), and****
****32(1) of the Regulation, the Group, as the****
****data controller, must take all necessary and appropriate technical****
****and organizational measures to ensure****
****an appropriate level of security for the****
****data it holds, including protection against unauthorized or****
****unlawful processing and against accidental loss,****
****destruction, or damage (Principle of****
****integrity and confidentiality) and must****
****demonstrate that processing is carried out****
****in accordance with the Regulation.****

4.3 ****In this case, a former member of****
****the Group gained access to****
****personal data held by the Group and****
****took possession of it. This****
****resulted in the availability of the personal****
****data of the Group's members being compromised,****

****indicating that the measures the Group had in**
****place, namely keeping the data in a locked**
****cabinet, were not**
****sufficient and appropriate for the security of the data.****

4.4 ****On the one hand, it is positively noted that**
****the Group had implemented measures to safeguard**
****the data it held; on the other hand, if the**
****measures in question had been appropriate and sufficient for**
****the intended purpose, unauthorized access to the data and**
****their loss would have been avoided.****

4.5 ****Regarding the first complaint submitted to**
****my Office against the Group and, specifically,**
****the part concerning the disclosure of**
****personal data of a member of the Group, during**
****the investigation of the complaint, it has not**
****been proven/indicated that the Group actually disclosed**
****the said data. Therefore, based on the evidence presented**
****before me, there does not appear to have been any violation of**
****the provisions of the Regulation.****

4.6. Regarding the first complaint and the existence of the possibility of viewing personal data of Group members in the reservation system, as well as regarding the second complaint concerning the posting of personal data of a Group member on the website, I find that the Group did not properly assess the risks that would arise for the rights of the data subjects. Had the Group conducted a proper assessment of these risks, it would have implemented, from the outset, the appropriate measures so that the processing it undertook would be in compliance with the Regulation and that personal data would not be disclosed to third parties.

4.7. It is positively noted that the Group cooperated excellently with my Office and promptly proceeded with the necessary corrective actions so that the processing ultimately became compliant with the provisions of the Regulation.

4.8. As a result of the above, the data controller did not implement the appropriate technical and organizational measures to ensure and be able to demonstrate that the processing was carried out in accordance with the Regulation, in violation of Article 24(1) of the Regulation.

4.9. It also emerges that the Group did not implement the appropriate technical and organizational measures to ensure an adequate level of security against risks, in violation of Article 32(1) of the Regulation.

4.10. Finally, the above demonstrates that the principle of integrity and confidentiality as provided in Article 5(1)(f) of the Regulation was not upheld.

5. Conclusion

5.1. Taking into account the above, as they have been presented to me and based on the powers granted to me under Articles 58 and 83 of Regulation (EU) 2016/679, I find that there has been a violation by the Group of Articles 5(1)(f), 24(1), and 32(1) of the Regulation.

5.2. Based on the provisions of Article 83 of the Regulation, to the extent that they apply in this specific case, I take into account the following mitigating (1)-(4) and aggravating (5)-(7) factors:

- (1) The absence of intent or willful violation by the Group.
- (2) The immediate cooperation and compliance with the requested actions of the supervisory authority.
- (3) The taking of immediate corrective actions after the identification of the violation.
- (4) The implementation of technical and corrective measures to prevent similar incidents in the future.
- (5) The absence of appropriate and sufficient technical and organizational measures.

- (6) The lack of ability to recover the data, the availability of which had been compromised.
- (7) The fact that the damage suffered by the Group members has not been remedied, as the data remains, to this day, in the possession of Ms. XXXX.

5.3. After considering and weighing:

- (a) the applicable legislative basis regarding the corrective powers conferred upon me by Article 58(2) of the Regulation,
- (b) the circumstances and factors presented by the Group based on all existing correspondence,
- (c) all the above mitigating and aggravating factors.

In my judgment and in accordance with the above provisions, I have decided to issue a reprimand to the Nicosia Tennis Club (Field Club) for the violation of Articles 5(1)(f), 24(1), and 32(1) of Regulation (EU) 2016/679.

Eirini Loizidou Nicolaidou

Commissioner for the Protection of Personal Data